



Chapter 13 – Vulnerability Assessment (VA) & Vulnerability Management



What is a Vulnerability?

A **Vulnerability** is a weakness, flaw, misconfiguration, or security gap in a system, software, network, application, operating system, or device that can be exploited by an attacker.



Simple Definition:

If a hacker can take advantage of a weakness to gain unauthorized access, steal data, execute malicious code, or disrupt services, that weakness is called a Vulnerability.



Real-Life Example

Imagine your house has:



Door unlocked



Broken window



Weak lock

These are physical vulnerabilities.

Similarly, in cybersecurity:



Weak passwords



Open ports



Disabled firewall



Outdated software

are security vulnerabilities.

Types of Vulnerabilities

1 Software Vulnerability

What is it?

Weaknesses found inside software applications, operating systems, drivers, or programs.

Examples:

- ◆ Remote Code Execution (RCE)
 - ◆ Buffer Overflow
 - ◆ Memory Corruption
 - ◆ Privilege Escalation
 - ◆ DLL Hijacking
-

Remote Code Execution (RCE)

One of the most dangerous vulnerabilities.

An attacker can remotely execute commands on a target machine.

Example

Suppose:

A company runs an outdated web application.

The application contains an RCE vulnerability.

An attacker sends a specially crafted request.

The server executes attacker commands.

Result:

- ✗ Data Theft
- ✗ Server Compromise
- ✗ Malware Installation

✗ Full System Control

2 Configuration Vulnerability

What is it?

Security weaknesses caused by incorrect system settings.

Common Configuration Issues

- 🔓 Guest Account Enabled
 - 🔥 Firewall Disabled
 - 🛡️ Secure Boot Disabled
 - ⚙️ Unnecessary Services Running
 - 📁 Shared Folders Open to Everyone
 - 🔑 Default Passwords
 - 📶 Open Wi-Fi Settings
-

Example

A Windows system has:

Guest Account = Enabled

Firewall = Disabled

Remote Desktop = Open

An attacker can easily gain access.

3 Authentication Vulnerability

What is it?

Weaknesses in login and identity verification mechanisms.

Examples

-  Weak Passwords
 -  No Multi-Factor Authentication (MFA)
 -  Password Reuse
 -  Default Credentials
 -  Shared Accounts
-

Example

Password:

123456

password123

admin123

These passwords can be cracked within seconds using brute-force attacks.

Network Vulnerability

What is it?

Weaknesses present in network infrastructure.

Examples

-  Open Ports
 -  Weak Encryption
 -  Unsecured Wi-Fi
 -  Insecure Protocols
 -  Misconfigured Routers
-

Insecure Protocol Examples

✗ Telnet

✗ FTP

✗ HTTP

Secure Alternatives:

✓ SSH

✓ SFTP

✓ HTTPS

5 Web Application Vulnerability

What is it?

Security flaws inside websites and web applications.

Common Web Vulnerabilities

💧 SQL Injection

🌐 Cross-Site Scripting (XSS)

📁 File Upload Vulnerability

🔒 Broken Authentication

📁 Directory Traversal

⚡ Remote File Inclusion

Example

A login page does not validate input.

Attacker enters:

' OR '1'='1

The attacker bypasses authentication.

This is SQL Injection.

What is Vulnerability Assessment (VA)?

Vulnerability Assessment is the process of:

- ✓ Finding vulnerabilities
- ✓ Identifying security weaknesses
- ✓ Measuring risk
- ✓ Creating reports
- ✓ Helping teams fix issues

before attackers exploit them.

Purpose of Vulnerability Assessment

Organizations perform VA to:

- ✓ Identify weak systems
 - ✓ Detect outdated software
 - ✓ Find missing patches
 - ✓ Discover misconfigurations
 - ✓ Improve overall security posture
-

Popular Vulnerability Assessment Tools

Nessus

One of the most popular vulnerability scanners.

Features:

- ✓ Vulnerability Detection
 - ✓ Compliance Checks
 - ✓ Patch Auditing
 - ✓ Configuration Auditing
-

Qualys VMDR

VMDR = Vulnerability Management, Detection and Response

Features:

- ✓ Asset Discovery
 - ✓ Vulnerability Scanning
 - ✓ Risk Prioritization
 - ✓ Patch Management
-

Learning Platform

You can learn Qualys through:

 Qualys Training & Certification

Important for SOC and Vulnerability Management roles.

Important certification:

 VMDR Certification

Rapid7 InsightVM

Features:

- ✓ Vulnerability Scanning
 - ✓ Asset Discovery
 - ✓ Risk-Based Prioritization
-

CrowdStrike

Famous for:

-  EDR (Endpoint Detection and Response)
 -  XDR (Extended Detection and Response)
 -  MDR (Managed Detection and Response)
-

Important CrowdStrike Certifications

-  MDR
-  XDR

Useful for:

- ✓ SOC Analyst
 - ✓ Threat Hunter
 - ✓ Security Operations
-

How Vulnerability Assessment Works

Let's understand step-by-step.

Step 1 – Asset Discovery

First, the tool identifies which devices are alive on the network.

How?

By sending:

-  ICMP Ping Requests
 -  TCP SYN Packets
 -  Nmap Discovery Scans
-

Example

Network contains:

-  Server
-  Laptop
-  Printer
-  Router

The scanner checks:

"Which devices are currently online?"

Devices responding are added to inventory.

Step 2 – Information Gathering

Now the scanner gathers information.

It identifies:

- ◆ Open Ports

- ◆ Operating System
 - ◆ Running Services
 - ◆ Installed Applications
 - ◆ Software Versions
-

Example

The scanner discovers:

Port 22 → SSH

Port 80 → HTTP

Port 443 → HTTPS

Operating System → Windows Server 2019

Apache Version → 2.4.49

Step 3 – Vulnerability Matching

Now collected information is compared with a vulnerability database.

The database contains:



CVEs



Known Vulnerabilities



Security Advisories



Vendor Patches

Example

Scanner detects:

Apache 2.4.49

Database says:

Apache 2.4.49 contains CVE-2021-41773.

The system is flagged as vulnerable.

Step 4 – Report Generation

The scanner generates a report showing:

-  Critical Vulnerabilities
-  High Vulnerabilities
-  Medium Vulnerabilities
-  Low Vulnerabilities

Report Contains

- ✓ CVE Number
 - ✓ Vulnerability Name
 - ✓ Severity
 - ✓ Affected Device
 - ✓ Remediation Steps
 - ✓ Patch Information
-

Step 5 – Remediation & Patching

Now the Vulnerability Assessment Engineer fixes the issues.

Possible Actions

-  Install Updates
-  Upgrade Software
-  Disable Services
-  Change Configuration

-  Enable Firewall
 -  Strengthen Authentication
-

What is a Zero-Day Vulnerability?

A vulnerability for which:

-  No Patch Exists
-  No Official Fix Exists
-  Vendor is unaware or recently informed

is called a:

 **Zero-Day Vulnerability**

Example

A hacker discovers a vulnerability in Windows.

Microsoft has not yet released a patch.

Attackers exploit it before a fix exists.

This becomes a Zero-Day Vulnerability.

Responsibilities of a Vulnerability Assessment Engineer

A Vulnerability Assessment Engineer is responsible for:

-  Running scans
-  Finding vulnerabilities
-  Reviewing reports
-  Applying patches
-  Hardening systems
-  Reducing attack surface

- ✓ Tracking remediation progress
-

Vulnerability Management Lifecycle

Asset Discovery



Information Gathering



Vulnerability Detection



Risk Assessment



Report Generation



Remediation



Verification Scan



Continuous Monitoring

Vulnerability Management Dashboard

Most enterprise tools provide dashboards where you can:

-  Create Sites
 -  Manage Assets
 -  Schedule Scans
 -  View Reports
 -  Check Scan History
 -  Track Remediation
 -  View Vulnerability Trends
-



Device Information Available in Dashboard

When clicking a scanned device, you may see:

- 📄 IP Address
 - 📄 Hostname
 - 📄 Operating System
 - 📄 Hardware Information
 - 📄 Network Interface
 - 📄 Last Scan Time
 - 📄 Next Scheduled Scan
 - 📄 Vulnerability Count
 - 📄 Risk Score
-



What is CVE?

CVE = Common Vulnerabilities and Exposures

A globally recognized identifier assigned to publicly known vulnerabilities.

Example

CVE-2021-44228

(Log4Shell Vulnerability)

You can search CVE IDs online to find:



Vulnerability Details



Available Patches



Severity Scores



Exploitation Information

Why Restart is Sometimes Required After Patching?

Many users install updates but do not restart systems.

As a result:

- ✗ Registry changes remain pending
- ✗ Drivers remain unloaded
- ✗ New files are not activated
- ✗ Old vulnerable services continue running

Example

Windows Update installs successfully.

But the user ignores:

 Restart Required

Until restart occurs, the patch may not be fully applied.

How Does a Vulnerability Scanner Detect Installed Software?

Many students ask:

"Nmap only shows ports and services. How does a vulnerability scanner know what software is installed?"

Windows Management Instrumentation (WMI)

Windows vulnerability scanners often use:

 WMI (Windows Management Instrumentation)

to gather detailed information.

Through WMI, scanners can access:

- ✓ Installed Software
- ✓ Registry Entries
- ✓ Running Processes
- ✓ Services
- ✓ System Information
- ✓ Event Logs
- ✓ Patch Levels

Authentication Method

A dedicated:

🔑 Service Account

is created.

The scanner authenticates using this account and collects detailed information from systems.

This is called:

Credentialed Scanning

Types of Vulnerability Scans

Non-Credentialed Scan

Scanner checks externally visible information only.

Can see:

- ✓ Open Ports
- ✓ Services
- ✓ OS Information

Cannot see:

- ✗ Installed Software
 - ✗ Registry
 - ✗ Local Configurations
-

Credentialed Scan

Scanner logs in using authorized credentials.

Can see:

- ✓ Installed Applications
- ✓ Registry
- ✓ Missing Patches
- ✓ Local Security Policies
- ✓ User Accounts
- ✓ Running Processes

More accurate than non-credentialed scans.

Free Vulnerability Assessment Tool

OpenVAS

OpenVAS (Open Vulnerability Assessment System) is a free and open-source vulnerability scanner.

Features:

- ✓ Vulnerability Scanning
- ✓ Network Assessment
- ✓ Web Application Checks
- ✓ Report Generation
- ✓ Scheduled Scans